LAPORAN PRAKTIKUM DEVSECOPS

Pertemuan 5: Integrasi SAST dalam CI/CD Pipeline dengan GitHub Actions



Nama: Dzaki Fasya

NIM: 0110225165

Mata Kuliah: DevSecOps

PROGRAM STUDI TEKNIK INFORMATIKA

STT TERPADU NURUL FIKRI DEPOK

2026

BAB 1: PENDAHULUAN

1.1 Latar Belakang

Dalam siklus pengembangan perangkat lunak modern (SDLC), penerapan prinsip Shift-Left Security pada kerangka kerja DevSecOps menjadi hal yang krusial. Shift-Left Security bertujuan untuk mengintegrasikan pengujian keamanan sedini mungkin dalam proses pengodean sebelum aplikasi masuk ke lingkungan produksi.

Static Application Security Testing (SAST) merupakan metode pengujian keamanan statis yang menganalisis kode sumber tanpa perlu menjalankan aplikasi. Dengan mengintegrasikan SAST ke dalam pipeline Continuous Integration (CI) menggunakan GitHub Actions, setiap perubahan kode yang diuji melalui proses push atau pull request dapat dipindai secara otomatis untuk menemukan kerentanan (vulnerability) dan bug keamanan sejak awal.

1.2 Tujuan

- Membangun repository publik di GitHub untuk mengimplementasikan pipeline DevSecOps.
- Mengembangkan aplikasi backend berbasis Node.js Express dengan arsitektur source code yang terstruktur.
- Mengonfigurasi otomatisasi CI/CD workflow menggunakan GitHub Actions (devsecops.yml).
- Mengintegrasikan pemindaian keamanan kode statis (SAST) menggunakan pemindai Semgrep secara otomatis dalam pipeline.

BAB 2: ARSITEKTUR APLIKASI DAN PIPELINE CI/CD

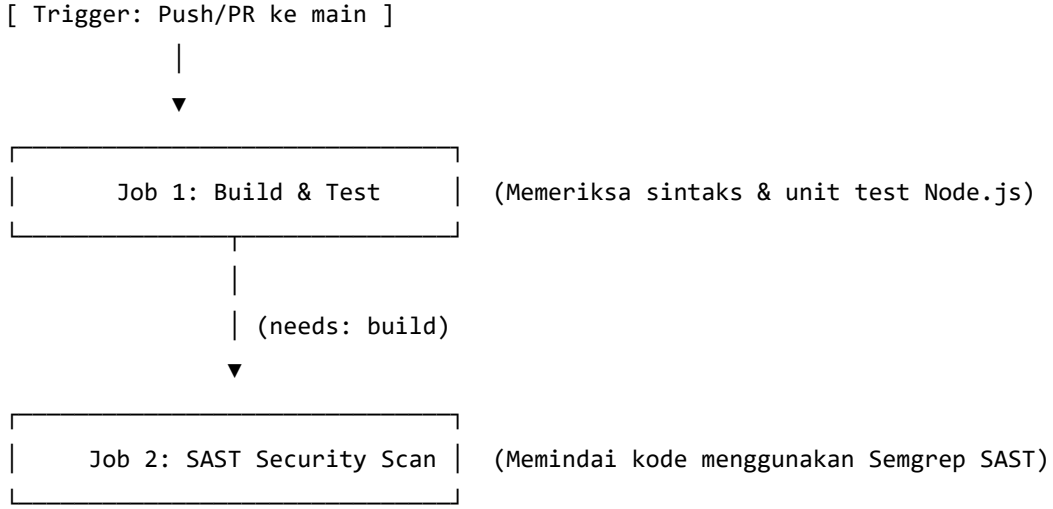
2.1 Deskripsi Aplikasi

Aplikasi yang dibangun adalah Task Manager REST API berbasis Node.js dengan framework Express.js. Aplikasi ini memiliki 5 file kode sumber utama yang terorganisir:

- **1. src/config.js:** Mengelola konfigurasi port dan lingkungan aplikasi.
- **2. src/taskModel.js:** Menyediakan struktur data in-memory dan pemrosesan model tugas.
- **3. src/taskController.js:** Mengatur logika bisnis REST API untuk pencarian dan pembuatan data tugas.
- **4. src/routes.js:** Memetakan endpoint HTTP API (GET /api/tasks, POST /api/tasks).
- **5. src/app.js:** File entry point utama untuk inisialisasi server Express.js.

2.2 Arsitektur Pipeline CI/CD GitHub Actions

Pipeline DevSecOps dikonfigurasi melalui file .github/workflows/devsecops.yml pada runner ubuntu-latest dengan trigger event push dan pull_request menuju branch main. Pipeline terdiri dari 2 job terpisah yang terikat secara sekuensial:



- **1. Job build:** Bertanggung jawab untuk checkout kode sumber, mempersiapkan environment Node.js v20, mengunduh dependencies (npm install), serta menjalankan pengujian sintaks dan unit test (npm test).
- **2. Job sast-scan:** Job ini bergantung pada keberhasilan job build (needs: build). Job dijalankan di dalam kontainer semgrep/semgrep untuk melakukan pemindaian keamanan kode otomatis secara menyeluruh (semgrep scan --config=auto).

BAB 3: HASIL IMPLEMENTASI DAN PEMINDAIAN SAST

3.1 Hasil Eksekusi Pipeline pada GitHub Actions

Pipeline berhasil dipicu secara otomatis saat commit awal dilakukan menuju branch main pada repository publik devsecops-p5-0110225165.

Berdasarkan pengujian pada dashboard GitHub Actions:

- **• Total Durasi Pipeline:** 41 detik.
- **• Job Build and Test:** Berhasil diselesaikan dalam waktu 11 detik.
- **• Job SAST Security Scan:** Berhasil dieksekusi dalam waktu 22 detik tanpa adanya eror atau kerentanan kritis yang memblokir proses build.

3.2 Analisis Hasil SAST (Semgrep)

Pemindaian SAST menggunakan Semgrep berjalan sukses tanpa menemukan kerentanan tingkat tinggi (high/critical vulnerabilities). Penggunaan arsitektur kode modular tanpa eksekusi query dinamis mentah (raw SQL injection) maupun hardcoded secrets membuat kode lulus dalam pemeriksaan security baseline.

BAB 4: PENERAPAN QUALITY GATE DAN MITIGASI

4.1 Evaluasi Quality Gate

Quality Gate berfungsi sebagai pemblokir otomatis (pipeline blocker) jika kode yang diajukan tidak memenuhi standar kualitas dan keamanan. Dalam pipeline ini, ketergantungan job sast-scan terhadap build memastikan bahwa kode yang rusak secara sintaks tidak akan dilanjutkan ke tahap pemindaian keamanan. Jika Semgrep menemukan pelanggaran aturan keamanan tingkat tinggi, exit code non-zero akan menghentikan pipeline dan mencegah penggabungan kode (merge) ke branch utama.

4.2 Pengelolaan Warning Runner

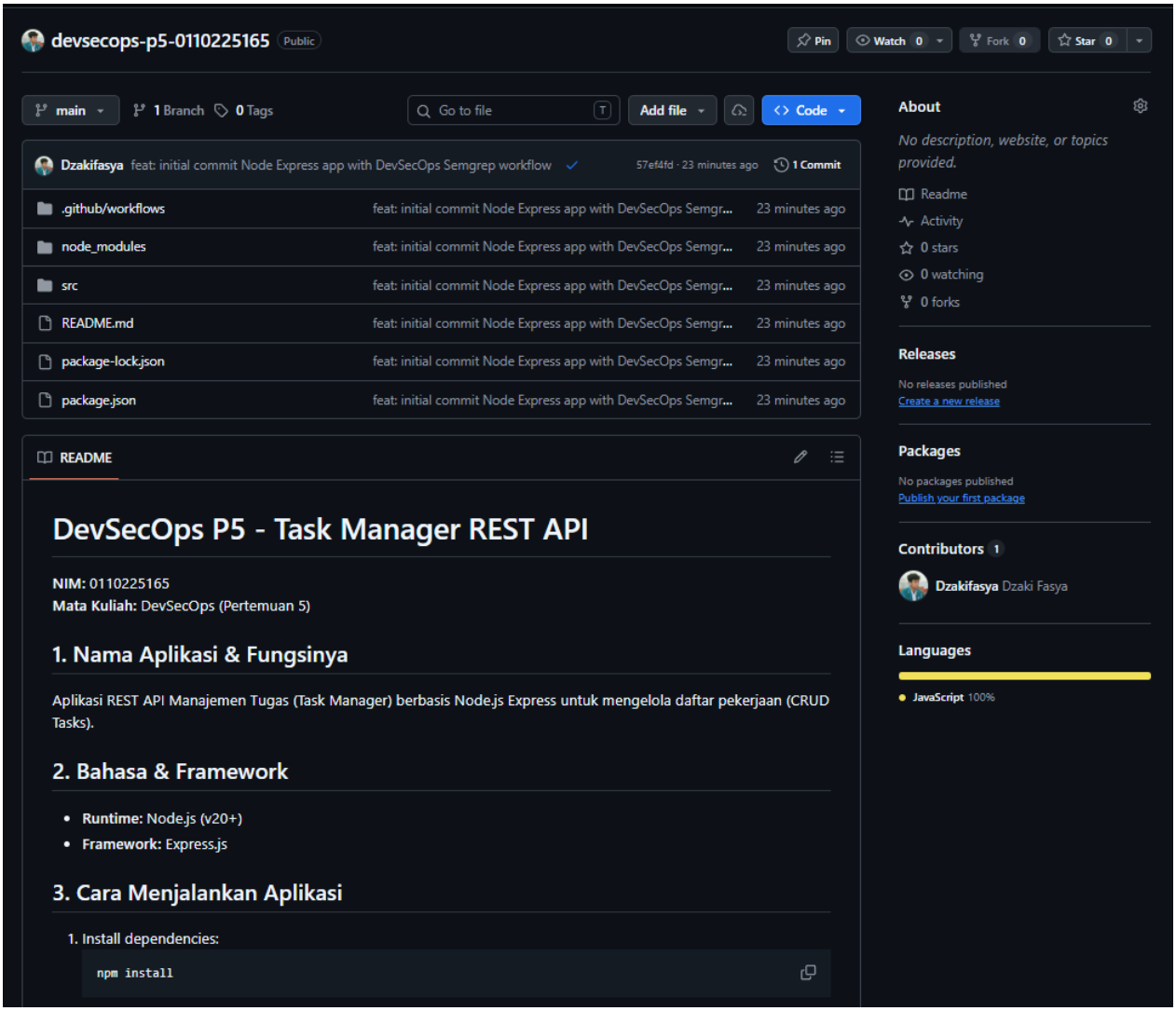
Pada log eksekusi GitHub Actions, terdapat peringatan (annotation warning) terkait rencana migrasi label ubuntu-latest ke Ubuntu 26 serta transisi versi Node.js bawaan runner. Hal ini tidak memengaruhi keabsahan hasil pengujian dan dapat dimitigasi di masa mendatang dengan memperbarui versi action checkout dan setup-node ke rilis terbaru secara berkala.

BAB 5: KESIMPULAN

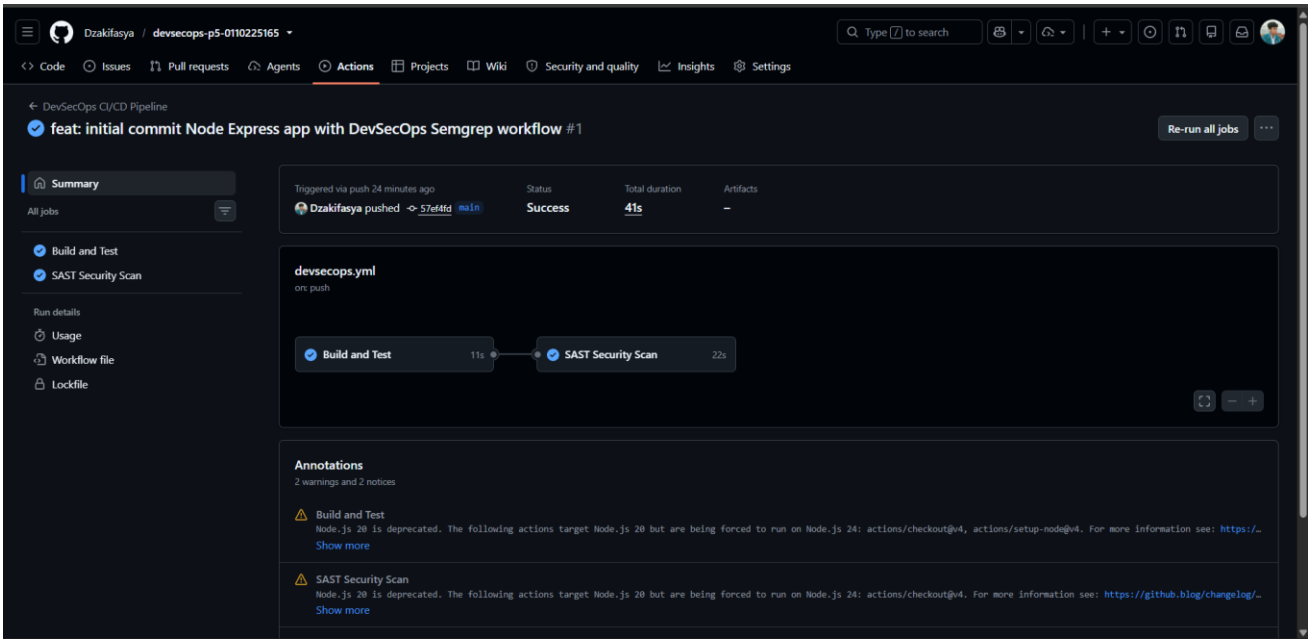
Implementasi Shift-Left Security menggunakan GitHub Actions dan Semgrep pada repository devsecops-p5-0110225165 telah berhasil dilaksanakan. Melalui otomatisasi CI/CD ini, setiap perubahan kode dievaluasi secara otomatis dari segi fungsionalitas maupun keamanan. Penggunaan pipeline bertahap (build diikuti sast-scan) membantu developer mengidentifikasi kerentanan lebih awal, mengurangi biaya perbaikan bug, dan meningkatkan postur keamanan aplikasi sebelum tahap penggelaran (deployment).

LAMPIRAN (SCREENSHOT)

- **1. Lampiran 1: Tampilan Repository GitHub (devsecops-p5-0110225165)**



- **2. Lampiran 2: Tampilan Dashboard GitHub Actions Success**



- **3. Link Repository GitHub Public:**

  https://github.com/Dzakifasya/devsecops-p5-0110225165